

Functional Requirements

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

19. Functional Requirements

Priority: M = Must (Phase 2 minimum), S = Should, C = Could. Evidence column: [P] primary (cite Q/interview once data exists), [S] secondary (cite ref), [A] labelled assumption. Until fieldwork completes, every [P] entry reads [DATA REQUIRED].

ID	Requirement	Rationale	Evidence	Priority	Screens
FR-01	A student can present a credential at a gate reader by tapping a smart card or an enrolled phone (NFC), or by showing a dynamic QR code from the app.	Universal baseline (card) plus convenience/fallback (phone) per D1.	[S] 13; [P] Q16, Q17 [DATA REQUIRED]	M	1, 2
FR-02	The system authenticates the credential by cryptographic challenge–response (card/NFC) or by verifying the signature and freshness of a dynamic QR token.	Prove possession of a key never transmitted; reject static identifiers.	[S] 1, 2, 4, 5	M	3
FR-03	The system checks credential validity: not expired, not revoked, not suspended, and (for visitor passes) within the issued time window.	Complete mediation; hotel-lock failures [8, 9] were failures of exactly this check.	[S] 2, 14	M	3, 7, 8, 15
FR-04	The system checks authorization: the authenticated principal's role and status permit entry at this gate at this time under the current policy.	Authorization is a distinct decision from authentication.	[S] 1, 14	M	3, 4, 5
FR-05	The system produces one of a fixed set of decisions: ALLOW; DENY—not recognised; DENY—expired; DENY—revoked; DENY—not authorized here/now; DENY—suspicious; and communicates it to guard and user.	Fixed vocabulary enables clear, consistent UI and logs.	[S] 12, 13	M	4–9
FR-06	The system records every access decision as an event containing: pseudonymous credential ID, gate ID, timestamp, method (card/NFC/QR/manual), decision code, and (for manual decisions) the guard's ID.	Auditability with minimisation.	[S] 22, 29	M	19
FR-07	An administrator can issue a credential to an identity in the roster, binding a card key or phone enrolment to that identity, and setting a validity period.	Credential lifecycle stage 1–2.	[S] 1 (800-63A), 2	M	17
FR-08	An administrator can revoke a credential with a recorded reason; revocation propagates to all gates within a defined time (target ≤30 s online; next sync offline).	Lifecycle stage 6; SEC-02.	[S] 2	M	17, 18
FR-09	A student can report their own card lost or stolen from the app or web portal, which immediately revokes that card while leaving any enrolled phone credential active.	Fast self-service revocation removes the window in which a lost card works; addresses H5.	[A]; [P] Q9, Q10 [DATA REQUIRED]	M	18
FR-10	A host (faculty/staff) can request a visitor pass specifying visitor name, purpose, date, time window and permitted gate(s); an approver (or auto-approval per policy) issues a signed, time-bound QR pass delivered to the visitor.	Replaces paper register; pre-approval moves work off the gate.	[A]; [P] B Q9 [DATA REQUIRED]	M	13, 14, 15
FR-11	Visitor passes expire automatically at the end of the window and cannot be extended without a new approval.	SEC-16.	[S] 2	M	15
FR-12	A guard can see the authentication and authorization result for the person at the gate, including the photo on file for the authenticated credential, display name, role, decision and reason, and can record a face-mismatch.	Human check defeats relay, borrowing and forgery of the printed card.	[S] 2, 13, 16	M	5, 16
FR-13	On any DENY, the system displays a defined next-step script to the guard and a minimal, non-accusatory message to the user; the guard cannot override a DENY into an ALLOW at the gate.	Fail-secure; consistent handling; no insecure bypass.	[S] 10, 13, 14	M	6–9, 12
FR-14	If the reader, network or database is unavailable, the reader continues to authenticate credentials locally using cached keys and a signed offline revocation list not older than a configured maximum age; if the list is older than that, or the reader itself fails, the system enters Manual Verification Mode with a defined procedure.	Availability without opening the gate.	[S] 2, 14	M	10, 11, 12
FR-15	An authorised auditor can review entry logs filtered by gate, time and decision; identities are pseudonymous by default and re-identification requires a recorded justification.	Auditability with privacy.	[S] 22, 26, 29	M	19
FR-16	A student can view their own entry events and the current status of each of their credentials.	Transparency; DPDP right of access [22].	[S] 22; [P] Q14b [DATA REQUIRED]	S	20
FR-17	The system detects repeated failed attempts (same credential ID, same gate, or same reader in a short window) and raises the decision to DENY—suspicious with an alert to the supervisor.	SEC-13.	[S] 29, 30	S	9, 16
FR-18	An administrator can define and update gate authorization policy (which roles may use which gates at which times) and the change is logged and versioned.	Authorization as data, not code; auditable policy.	[S] 14	S	20
FR-19	Manual Verification Mode records each manual decision with the guard's ID, the credential (if any) presented, and the verification steps taken, and flags all such events for later review.	Fallback remains auditable.	[S] 29	M	12

ID	Requirement	Rationale	Evidence	Priority	Screens
FR-20	Emergency egress is never blocked by the system; emergency ingress for first responders follows a supervisor-authorised procedure that is logged.	Life-safety supersedes access control; but ingress remains controlled.	[S] 31	M	12